

DDTA - Scheda di lettura compilata

SRC-0026 - Tuma, Calikli e Scandariato (2018) - SLR sulle tecniche di threat analysis

Identita bibliografica

Campo	Valore
Titolo	Threat analysis of software systems: A systematic literature review
Autori	Katja Tuma; Gul Calikli; Riccardo Scandariato
Sede	Journal of Systems and Software, 144, 275-294
DOI	10.1016/j.jss.2018.06.073
Corpus	38 studi primari; 26 tecniche
Finestra	Studi pubblicati prima di gennaio 2017
Accesso	Preprint ospitato dagli autori

Validita temporale

Dimensione	Valutazione
Tipo	Revisione sistematica e tassonomia comparativa
Sensibilita	Alta per tool e automazione; media per categorie concettuali
Stato	Baseline storica; non stato dell'arte 2026
Ancora valido	Input/procedura/output/assurance/DoD/validation come dimensioni
Obsoleto senza update	Maturita tool, DevOps, automazione e disponibilita
Uso tesi	Fondare tassonomia e gap storico; non descrivere tool attuali

Risultato centrale: la maggior parte delle tecniche opera prima dell'implementazione. Tuttavia quasi tutte presuppongono che documenti e conoscenza siano gia stati trasformati in requisiti, obiettivi, scenari o modelli.

Domanda 1 - Problema e contributo

La revisione confronta le tecniche non soltanto per tassonomia delle minacce, ma per livello di astrazione, input, procedura, risultati, facilita di adozione e validazione. Il processo di selezione riduce 5.000 risultati a 38 studi e 26 tecniche.

Domanda 2 - Artefatti iniziali

Gli input osservati sono obiettivi, requisiti, comportamento dell'attaccante, assunzioni di sicurezza, progetto architetturale e codice. Le rappresentazioni sono testuali, model-based o altre. L'articolo non studia l'estrazione automatica da documenti grezzi.

SRC-0026 - Compatibilita documentation-first

Livello di applicabilita

Livello	Numero di tecniche	Significato DDTA
Requisiti	14	Prima dell'architettura dettagliata
Architettura	11	Richiede una vista architetturale
Design	13	Richiede decisioni e modelli piu dettagliati
Implementazione	2	Sistema concreto o codice

Input osservati

Input	Conteggio	Classificazione DDTA
Progetto architetturale	12 pubblicazioni	documentation_plus_model
Requisiti	11	documentation_primary
Assunzioni di sicurezza	7	documentation_primary
Comportamento attaccante	6	knowledge_plus_documentation
Obiettivi di alto livello	5	documentation_primary
Codice sorgente	1, opzionale	later_iteration
Descrizione testuale	15	representation
Modello	11	representation
Testo + modello	4	representation

Separazione metodologica DDTA

La revisione sostiene che il codice non e normalmente richiesto per l'analisi iniziale. Non dimostra invece che la documentazione grezza contenga gia una rappresentazione sufficiente.

Passaggio	Copertura della revisione
Documentazione -> Base Analysis	Non studiato direttamente
Base Analysis/modello -> minacce	Nucleo della maggior parte delle tecniche
Minacce -> mitigazioni/requisiti	Presente in una parte consistente
Codice -> conferma/contraddizione	Proposto come feedback futuro

Famiglie

Famiglia	Centro dell'analisi
Risk-centric	Asset, valore, rischio e rischio residuo
Attack-centric	Attaccante, percorso e copertura delle minacce
Software-centric	Elementi del software o dell'architettura
GORE/SRE	Obiettivi, anti-obiettivi e requisiti di sicurezza
Privacy	Minacce e requisiti di privacy

SRC-0026 - Procedure, risultati e assurance

Procedura

Dimensione	Risultato
Knowledge base	Circa meta delle tecniche
Precisione	Spesso esempi o template
Molto precise/formali	Quattro famiglie
Semi-automatizzate	Sei tecniche
Precisione non affrontata	Circa sette tecniche
Attività umane centrali	Identificazione e prioritizzazione delle minacce

Risultati

Output	Conteggio
Minacce	Tutte le tecniche
Mitigazioni	15
Requisiti di sicurezza	12
Tutti e tre	8
Output ad alto livello	25 tecniche

Quality assurance e adozione

Dimensione	Conteggio / esito
Assurance esplicita	3
Assurance presente ma non esplicita	5
Assurance non presente	17
Nessun tool	11
Tool	11
Prototype tool	4
Guidance fine-grained	6
Case study, definizione ampia	19
Experiment	8
Illustration	9

Gap rilevati

- Manca una Definition of Done.
- Le regole sono spesso vaghe o informali.
- I tool aiutano la rappresentazione più della scoperta semantica.
- Correttezza e completezza raramente sono assicurate.
- Traceability, composabilità e change impact restano deboli.

Conseguenza DDTA: ogni overlay deve dichiarare input, regole, diagnostica, copertura, condizione di arresto, output tipizzati e verifica.

SRC-0026 - Selezione delle prossime letture

Cosa abbiamo dimostrato

- La prima analisi può essere svolta senza codice.
- Testo, requisiti e obiettivi sono input legittimi.
- Alcune metodologie richiedono invece un modello architetturale.
- Il passaggio documento -> modello neutrale non è risolto dalla revisione.
- Threat, mitigazione e requisito sono output distinti.
- Assurance e completamento devono essere progettati esplicitamente.

Cosa non possiamo sostenere

- Che qualsiasi documentazione sia sufficiente.
- Che la documentazione venga trasformata automaticamente in Base Analysis.
- Che i tool del 2018 rappresentino lo stato attuale.
- Che una tecnica sia empiricamente superiore alle altre.
- Che il gap rilevato prima del 2017 sia rimasto identico.

Coda di lettura primaria

Priorità	Fonte	Perché
1	SRC-0003 - Sindre e Opdahl	Use case -> misuse case; testo documentation-primary
2	SRC-0004 - van Lamsweerde	Goal -> anti-goal -> security requirement
3	Haley et al.	Threat descriptions + satisfaction arguments
4	Whittle et al.	Scenari, mitigazioni e verifica comportamentale
5	Hatebur e Heisel	Problem frames e descrizione strutturata del problema
6	Studio empirico STRIDE recente	Aggiornare DFD overlay e prestazioni umane

Matrice per le prossime fonti

Campo	Domanda
Input	Quale documento o modello è obbligatorio?
First-analysis fit	Funziona prima del codice?
Representation	Quali entità, relazioni, flussi e boundary usa?
Procedure	Quali regole trasformano input in candidati?
Output	Threat, finding, mitigazione o requisito?
Provenance	Il risultato è collegato alla fonte?
Assurance	Come si misurano correttezza e completezza?
Evolution	Come reagisce ai cambiamenti?

Decisione sul corpus

Questa fonte apre il cluster delle metodologie. Le prossime due letture non sono nuove ricerche casuali: sono SRC-0003 e SRC-0004, già registrate, da completare con note, estratti e confronto documentation-first.